Audit Finding AF-001

Delayed removal of access for terminated employees (Control AM-02)

Finding ID	AF-001	**Rating**	**High - Significant deficiency**
Control	AM-02: Accounts of terminated employees are disabled within 24 hours of the HR termination date	**Audit period**	July 1 - September 30, 2026
Control owner	IT Security Manager	**Report date**	October 16, 2026
Related risk	R-010 Orphaned access from incomplete offboarding (score 12, High)	**Framework refs**	NIST CSF 2.0 PR.AA-05; SOC 2 CC6.3
Related asset	A-001 Microsoft Entra ID tenant	**Status**	Open

1. Finding

The control requiring terminated employees' accounts to be disabled within 24 hours did not operate effectively during the audit period. **3 of 25 sampled terminations (12%)** were disabled late, between 3 and 15 days after the termination effective time. One of these accounts recorded a **successful sign-in after the employee was terminated**. Extended review of all 38 terminations in the period found **5 late disables (13.2%)**, all of which were handled manually rather than by the automated Workday-to-Entra process.

2. Condition

A sample of 25 of 38 terminations was tested against Workday termination data and Entra ID audit logs. The effective time of each termination was taken as 17:00 ET on the termination date. Because exceptions were found, testing was extended to the full population. All five late disables are shown below.

Employee ID	Dept.	Type	Effective date	Account disabled	Hours to disable	Method	In sample?
E2009	Sales	Involuntary	2026-07-17	2026-08-01 18:00	361	Manual	Yes
E2034	Sales	Voluntary	2026-08-03	2026-08-12 15:00	214	Manual	No
E2031	Engineering	Voluntary	2026-08-17	2026-08-21 22:00	101	Manual	Yes
E2013	Customer Svc.	Voluntary	2026-09-17	2026-09-21 00:00	79	Manual	Yes
E2028	Finance	Retirement	2026-07-09	2026-07-11 21:00	52	Manual	No

- **Post-termination access:** E2009 (involuntary termination, Sales) had a successful sign-in on 2026-07-20 at 19:00, about three days after the termination. The account stayed enabled until August 1.
- **Automated process performed well:** all 33 automated disables completed within 24 hours (longest 19.7 hours). Every exception was a manual disable via a service desk ticket.
- **Rate:** 3 of 25 sampled (12.0%); 5 of 38 in the full population (13.2%). The tolerable deviation for this control is 0.

3. Criteria

Apex Access Control Policy and control AM-02 require that user accounts are disabled within 24 hours of the HR termination date. The requirement supports NIST CSF 2.0 PR.AA-05 (access permissions are managed,

incorporating least privilege) and SOC 2 criterion CC6.3 (access is removed when no longer required).

4. Cause

Preliminary causes, based on the evidence and to be confirmed with management:

- **Late HR entry (3 of 5):** E2013, E2028 and E2031 were entered in Workday 2 to 4 days after the termination effective date, so the automated sync could not act on time.
- **No automated disable (2 of 5):** E2009 and E2034 were entered in Workday on time or earlier, yet the accounts were disabled manually 9 and 15 days later. The reason the automated sync did not process them is not evidenced and needs investigation.
- **No detective control:** there is no daily reconciliation of terminated employees against enabled Entra ID accounts, so late or failed disables were not detected.

5. Risk

Terminated users retaining access can view, change or exfiltrate customer and financial data, and may do so with malicious intent after an involuntary termination. The observed post-termination sign-in shows the risk has already materialized in at least one case. This finding relates to risk **R-010 (Orphaned access from incomplete offboarding; Likelihood 3, Impact 4, score 12, High)** and increases confidence that the likelihood is at least as high as rated. It could also lead to an adverse SOC 2 opinion on CC6.3 and regulatory findings on access controls.

6. Recommendation

1. **Investigate E2009 immediately.** Review all activity from the account between 2026-07-17 17:00 and 2026-08-01 18:00, including data accessed, and document the conclusion.
2. **Add a daily reconciliation.** Compare Workday terminations with enabled Entra ID accounts and create a ServiceNow alert for any account still enabled 12 hours after termination.
3. **Set an HR entry standard.** Terminations must be entered in Workday before the effective time (same business day for involuntary terminations), with a monthly timeliness report to the CISO.
4. **Fix the automation.** Determine why the Workday-Entra sync did not process E2009 and E2034, and add failure alerting to the integration.
5. **Interim measure.** For involuntary terminations, HR calls the Security team and the service desk disables the account the same day under a priority ticket.
6. **Retest.** Re-perform AM-02 over the full Q4 2026 population after remediation.

7. Management response

Management response (fictional), received October 28, 2026, from the IT Security Manager and HR Operations: Management agrees with the finding and the recommendations. The Security team has started a review of the post-termination sign-in on E2009 and will report to the CISO. HR Operations will introduce a Workday entry deadline for terminations, and the IT Security Manager will deliver the daily reconciliation and sync alerting. Until automation is fixed, involuntary terminations will be handled by same-day manual ticket. Management accepts the proposed remediation dates below.

8. Remediation plan and dates

#	Action	Owner	Due date
1	Investigate post-termination activity on E2009 and report	Security Operations Lead	2026-11-13
2	Interim same-day manual disable process for involuntary terminations	IT Service Desk Manager	2026-11-06
3	Workday entry deadline and monthly timeliness report	HR Operations	2026-11-30
4	Daily Workday-to-Entra reconciliation with 12-hour ServiceNow alert	IT Security Manager	2026-12-11
5	Root-cause and fix sync failures; add integration failure alerts	IAM Lead	2026-12-18
6	Retest AM-02 on full Q4 2026 population	Compliance Manager	2027-01-29

Evidence and workpapers: Evidence/Access-Termination-Evidence.xlsx; ITGC-Test-Results.xlsx (sheets AM-02 and Exception Log, exceptions EX-003 to EX-005); ITGC-Control-Matrix.xlsx; Risk-Register.xlsx (R-010).

Simulated document. All names, dates, systems and results are fictional and created for portfolio purposes. No real organization's information is used.